

WEEK 1 — OBJECTIVE 1

**Cybersecurity Threats Associated with BMS in Vehicles and Security
Controls Required for Their Mitigation**

Name: Rishabh Bhaskar

Table of Contents

1. Threat Landscape Overview	3
2. Detailed Attack Catalog	3
A. Communication Attacks (In-Vehicle & Wireless Networks)	3
B. Sensor & Physical Attacks	5
C. Software, Firmware & Algorithm Attacks	6
D. External & Ecosystem Attacks	8
E. Emerging Threats from Grid, Cloud & Supply-Chain Integration	9
3. Security Control Architecture	10
3.1 Controls by System Layer	10
3.2 Defense-in-Depth Visualization	11
4. Security Control-to-Cyber Threat Reference Matrix	12
5. Security Controls	12
5.1 Message Authentication and Integrity	12
5.2 Encryption	13
5.3 Freshness Mechanisms / Anti-Replay Protection	13
5.4 Secure Boot	14
5.5 Digital Signatures	14
5.6 Anti-Rollback / Downgrade Protection	15
5.7 Hardware Security Module (HSM) / Secure Element	15
5.8 Network Segmentation and Secure Gateways	16
5.9 Intrusion Detection and Anomaly Detection	16
5.10 Sensor Redundancy and Plausibility Checking	17
5.11 Secure Diagnostics and Debug Protection	18
5.12 Secure Over-the-Air (OTA) Updates	18
5.13 Authentication and Access Control	19
5.14 Secure Logging and Tamper Protection	19
6. Key Security Measures for BMS	20
7. Roadmap for a Cyber-Resilient BMS	21
8. Regulatory Alignment	21

1. Threat Landscape Overview

BMS threats are grouped into five domains based on the attack surface they exploit.

Category	Representative Threats	Typical Impact
Communication Attacks	DoS, Sniffing, MITM, Jamming, Spoofing, Replay, Fuzzing	Disrupted charging cycles, data leakage, false data injection
Physical & Sensor Attacks	Hardware Tampering, EMI/Fault Injection, IC Counterfeiting, Sensor Manipulation	Malfunctions, data theft, hidden malware risk, overcharge/overheat
Software, Firmware & Algorithm Attacks	Malware, Ransomware, Trojan, Modeling Attacks, Timestamp Manipulation, Rollback	Unauthorized control, system lockout, false SoC/SoH readings, misleading logs
External & Ecosystem Attacks	EVSE/V2G, Cloud/API, Supply Chain, Telematics Pivoting, OBD-II	Fleet-wide remote immobilization, pack bricking, hardware backdoors
Emerging (Grid/Cloud/Supply Chain)	Second-Life Data Theft, ML Poisoning	Data exposure post-decommission; fleet-wide estimation drift

2. Detailed Attack Catalog

Each threat below is broken into five parts: what the attack is, how it is actually carried out, the specific BMS impact, the security control engineered to defeat it, and why that control works mechanically. Threats are grouped by category and individually referenced by ID for traceability against the risk matrix.

A. Communication Attacks (In-Vehicle & Wireless Networks)

Exploit the lack of encryption or authentication in internal vehicle wiring (CAN, LIN, automotive Ethernet) or short-range wireless BMS (wBMS) links.

Attack Surface:

Internal vehicle communication networks such as CAN, LIN and Automotive Ethernet, as well as wireless BMS (wBMS) communication links.

Weakness:

Insufficient authentication, integrity protection, encryption or freshness mechanisms.

BMS-T01 Sniffing / Eavesdropping [Communication]

What is it?	Passive interception of unencrypted traffic travelling on in-vehicle buses (CAN, LIN, automotive Ethernet) or wireless BMS links.
Attack Mechanism	Attacker taps a bus wire, plugs into an exposed connector such as the OBD-II port, or places an RF receiver near a wireless BMS module, and silently logs raw traffic.
BMS Impact	Exposure of cell voltages, SoC/SoH values, temperature data, and proprietary parameters — also gives reconnaissance for later spoofing or replay.
Security Control	AES-256 encryption of bus/wireless payloads; TLS 1.3 for cloud-facing links.
How the Control Works	Encrypting data in transit turns intercepted bytes into ciphertext without the session key, so tapping the wire yields no usable information.

BMS-T02 Spoofing / Message Injection [Communication]

What is it?	Transmission of forged messages accepted by the network as legitimate BMS or vehicle traffic.
Attack Mechanism	After gaining bus access via a compromised ECU, exposed OBD port, or breached wireless gateway, the attacker transmits a crafted CAN frame using a legitimate arbitration ID (e.g. a fake HV-fault message).
BMS Impact	False data injection that can trigger unwarranted contactor shutdown, incorrect SoC/SoH reporting, or mask a genuine fault.
Security Control	SecOC (Secure Onboard Communication) message authentication.
How the Control Works	Every message carries a cryptographic MAC from a shared key and freshness counter; a forged frame sent without the key fails verification and is discarded.

BMS-T03 Man-in-the-Middle (MITM) [Communication]

What is it?	The attacker sits between two legitimate BMS components and covertly intercepts and alters traffic passing between them.
Attack Mechanism	A compromised gateway ECU or rogue wireless node relays messages between the CMUs and BMU, modifying values before forwarding.
BMS Impact	False battery-state reports and incorrect cell-balancing commands, leading to degraded pack health and unsafe charge/discharge decisions.
Security Control	Mutual authentication with short-lived, rotating session keys.
How the Control Works	Both endpoints must prove identity through challenge-response before data flows, and keys expire quickly, so an inserted node cannot silently relay or tamper without breaking the session.

BMS-T04 Replay Attack [Communication]

What is it?	Capturing a legitimate command and retransmitting it later, outside its original context.
Attack Mechanism	Attacker records a validly authenticated frame — e.g. a 'disconnect HV contactor' diagnostic command — and rebroadcasts it while the vehicle is moving at speed.
BMS Impact	Unexpected loss of drive power or unsafe contactor drop at highway speed — a direct safety hazard.
Security Control	Freshness counters/timestamps combined with the SecOC MAC.
How the Control Works	Each authenticated message embeds a monotonically increasing counter; a replayed frame carries a stale counter and is rejected even though its MAC still checksums correctly.

BMS-T05 Denial-of-Service (DoS) [Communication]

What is it?	Flooding the vehicle communication bus with high-volume or high-priority traffic to block legitimate messages.
Attack Mechanism	Attacker injects a burst of high-priority (low arbitration ID) CAN frames, or garbage traffic on Ethernet/MQTT channels, saturating bandwidth.
BMS Impact	Safety-critical warnings (fire, overheating) are delayed or dropped; safe charge/discharge cycles are disrupted.
Security Control	Real-time IDS with rate limiting, combined with network segmentation.
How the Control Works	The IDS monitors message rate/pattern per arbitration ID and throttles or isolates an offending node, while segmentation confines the flood to one sub-network.

BMS-T06 Jamming [Communication]

What is it?	Radio-frequency interference directed at the exact frequency used by a wireless BMS (wBMS) system.
Attack Mechanism	Attacker broadcasts noise at the wBMS operating frequency, preventing cell monitor units from communicating with the master controller.
BMS Impact	Data loss and incorrect charging/discharging decisions, potentially forcing an unplanned fail-safe shutdown.
Security Control	Frequency Hopping Spread Spectrum (FHSS) paired with dynamic AES keys.
How the Control Works	The link hops rapidly across frequencies in a pattern known only to paired devices, so a jammer fixed on one frequency cannot block the conversation.

BMS-T07 Fuzzing [Communication]

What is it?	Sending malformed, unexpected, or randomized network messages to discover vulnerabilities or trigger malfunctions.
Attack Mechanism	Attacker with bus access transmits out-of-specification CAN payloads — invalid lengths, out-of-range values, malformed fields — and observes ECU/BMS response.
BMS Impact	ECU or BMS crashes/malfunctions, or exposure of exploitable parsing bugs weaponizable in a follow-up attack.
Security Control	Strict input validation and secure coding practices, layered on top of SecOC to restrict who can inject frames.
How the Control Works	Rigorous schema/range validation on every received field rejects out-of-spec data before it reaches processing logic.

B. Sensor & Physical Attacks

Manipulate physical reality or the BMS hardware itself, rather than the data flowing across a network.

Attack surface:

Battery sensors and their interfaces, including voltage, current and temperature sensors; sensor wiring; ADC/input interfaces; BMS electronic control hardware; memory; debug/programming interfaces; and physical access to battery/BMS components.

Weakness:

Sensors and physical interfaces may be exposed to manipulation, tampering or injected signals. The BMS may also have limited ability to distinguish genuine physical measurements from deliberately manipulated measurements. Insufficient physical protection, inadequate sensor validation, or insufficient redundancy can increase this exposure.

BMS-T08 Temperature Sensor Manipulation [Physical / Sensor]

What is it?	Falsification of thermal readings reported to the BMS.
Attack Mechanism	A direct wiring tap on the NTC thermistor, or an external heat gun / freeze spray on the sensor, shifts the reported resistance and apparent temperature.
BMS Impact	Masks a genuine overheating condition (overcharge/thermal-runaway risk) or spoofs a false high reading forcing unnecessary shutdown.
Security Control	Plausibility checking / analytical redundancy using a real-time thermal model (digital twin).
How the Control Works	The BMS compares reported temperature against a physics-based prediction from current draw and coolant flow; a reading that violates expected behaviour is flagged as anomaly.

BMS-T09 Voltage / Current Sensor Manipulation [Physical / Sensor]

What is it?	Falsification of shunt-resistor or cell-voltage readings used to estimate pack state.
Attack Mechanism	Physical tampering with shunt wiring, or direct signal injection, alters the reported current/voltage fed into the SoC calculation.
BMS Impact	Incorrect SoC estimation driving the pack into over-discharge or overcharge, both accelerating cell degradation.
Security Control	Sensor redundancy cross-checked against a coulomb-counting estimation model.
How the Control Works	Independent redundant sensors and model-based estimates are continuously cross-validated; a mismatch beyond tolerance raises a fault flag.

BMS-T10 Hardware Tampering [Physical / Sensor]

What is it?	Direct physical intrusion into the BMS enclosure to access its internals.
Attack Mechanism	Attacker opens the casing to probe circuit boards, splice signal lines, or access memory and debug pins directly.
BMS Impact	Data theft, malfunction, and potential full system hijack once internal buses or memory are exposed.
Security Control	HSM with active tamper shields, plus secured (fused-off) debug interfaces.
How the Control Works	Active shielding detects intrusion or abnormal voltage/clock behaviour and zeroizes stored keys; JTAG/SWD ports are permanently locked at end of assembly.

BMS-T11 EMI / Fault Injection [Physical / Sensor]

What is it?	Use of targeted electromagnetic interference or laser pulses to induce faults inside the BMS microcontroller.
Attack Mechanism	Attacker directs precise EMI or laser pulses at the chip to flip bits in RAM, potentially causing the CPU to skip a code-authentication check ('glitching').
BMS Impact	Sensor malfunctions, false fault triggers, and possible bypass of security checks such as secure-boot verification.
Security Control	Environmental glitch detectors (voltage and clock monitors) built into the HSM.
How the Control Works	Onboard monitors watch supply voltage and clock integrity; any transient consistent with a glitch attempt forces the chip into safe lockout.

BMS-T12 Counterfeit IC / Hardware Trojan [Physical / Sensor]

What is it?	Substitution of genuine ICs with fake or maliciously modified components containing hidden logic.
Attack Mechanism	Attacker intercepts the supply chain and swaps or modifies chips during manufacturing/assembly, embedding a backdoor that activates on a secret trigger.
BMS Impact	Reduced reliability and a hidden backdoor capable of disabling safety cut-offs or short-circuiting cells on command.
Security Control	Cryptographically verified component pairing and supply-chain attestation.
How the Control Works	Each genuine IC is provisioned with a unique cryptographic identity at the fabrication facility; the BMS verifies this at boot and rejects unpaired chips.

BMS-T13 Sensor Fault Injection / Spoofing (General) [Physical / Sensor]

What is it?	Broader class of forcing any BMS sensor — pressure, current-limit, or others — to report incorrect values.
Attack Mechanism	Direct signal injection, wiring manipulation, or environmental spoofing (magnets, heat sources) applied to any sensor type feeding the BMS.
BMS Impact	Any safety/control decision depending on the affected sensor — charging limits, balancing, contactor cut-off — becomes unreliable.
Security Control	Multi-sensor data fusion with plausibility bounds applied across all sensor types.
How the Control Works	Correlating multiple independent, physically-linked measurements means a spoofed sensor stands out as statistically inconsistent and is down-weighted.

C. Software, Firmware & Algorithm Attacks

Target the operating logic, calculations, and binaries executed on the BMS processor.

Attack surface:

BMS firmware, software/operating logic, battery-management algorithms, memory, bootloader, firmware-update mechanisms, configuration parameters, and software interfaces used by the BMS.

Weakness:

Software vulnerabilities, insecure firmware, inadequate input validation, weaknesses in update mechanisms, insecure algorithms or implementation errors can allow attackers to modify, exploit or influence BMS behaviour. Poor protection of firmware and cryptographic keys can further increase the attack surface.

BMS-T14 Malware Injection [Software / Firmware]

What is it?	Installation of rogue processes onto the BMS or vehicle gateway.
Attack Mechanism	Delivered through a compromised firmware update, physical access to a debug port, or a pivot from an already-compromised infotainment/telematics unit.
BMS Impact	Unauthorized access, silent exfiltration of operational metrics, and manipulation of system control.
Security Control	Secure Boot with code signing.
How the Control Works	At every boot, the bootloader verifies a cryptographic signature over the firmware image against a hardware root-of-trust key; unsigned or altered code fails verification.

BMS-T15 Trojan Horse [Software / Firmware]

What is it?	Malicious code disguised as a legitimate software update.
Attack Mechanism	Attacker packages malware inside what appears to be an official performance/feature update, distributed via social engineering, a compromised update server, or physical media.
BMS Impact	Data theft and silent manipulation of BMS behaviour while appearing to function normally.
Security Control	Digital signature verification of every firmware package.
How the Control Works	Only updates signed with the OEM's private key pass verification, so a Trojanized package lacking a valid signature is rejected regardless of disguise.

BMS-T16 Malicious Firmware / OTA Attack [Software / Firmware]

What is it?	Delivery of an unauthorized, rogue firmware image over the air.
--------------------	---

Attack Mechanism	Exploiting a weak OTA update server, poor TLS configuration, or stolen signing credentials to push firmware that rewrites maximum charging thresholds.
BMS Impact	System control manipulation and unsafe charging limits, with fleet-wide risk if distributed broadly.
Security Control	Encrypted, signed OTA delivery (TLS 1.3) combined with the secure-boot chain.
How the Control Works	The update is encrypted in transit and signed at the source; the bootloader only accepts images whose signature chains back to the OEM root of trust.

BMS-T17 Rollback Attack [Software / Firmware]

What is it?	Forcing the BMS to downgrade to an older, known-vulnerable firmware version.
Attack Mechanism	Attacker replays an old but validly-signed firmware image — which still passes signature checks — to reintroduce an already-patched vulnerability.
BMS Impact	Reopens known exploitable weaknesses and undermines the protection of all subsequent patches.
Security Control	Anti-rollback protection using a monotonic hardware version counter.
How the Control Works	A secure counter records the minimum acceptable firmware version; the bootloader refuses any image with a lower version number, even if validly signed.

BMS-T18 Modeling / Algorithm Manipulation [Software / Firmware]

What is it?	Exploitation or corruption of the BMS's State-of-Charge (SoC) and State-of-Health (SoH) estimation algorithms.
Attack Mechanism	Attacker feeds crafted input data or directly alters model parameters/weights so the algorithm produces an inaccurate SoC/SoH calculation.
BMS Impact	False SoC/SoH readings that drive over-discharge or overcharge and accelerate cell chemistry wear.
Security Control	Cryptographic validation of model parameters, plus sanity-bounded outputs.
How the Control Works	Model coefficients are signed and checksummed before use, and outputs are bounded against physically plausible ranges, catching manipulated models before they drive a decision.

BMS-T19 False Data Injection [Software / Firmware]

What is it?	Deliberate feeding of erratic data into the cell-balancing engine.
Attack Mechanism	A compromised sensor node or direct bus injection supplies fabricated voltage/current matrices to the balancing algorithm.
BMS Impact	Pack imbalance, accelerated cell degradation, and premature cell failure.
Security Control	SecOC message authentication combined with data plausibility/outlier filtering before balancing decisions.
How the Control Works	Authenticated messaging blocks unauthorized sources, and statistical outlier detection flags values inconsistent with neighbouring cells before they influence balancing.

BMS-T20 Timestamp / Log Manipulation [Software / Firmware]

What is it?	Alteration of event timestamps or stored log entries.
Attack Mechanism	Attacker with write access to the log store or real-time clock modifies stored records to hide an event or misrepresent charge-cycle history.
BMS Impact	Misleading fault logs, incorrect charge-cycle counts, and obstructed warranty or forensic audits.
Security Control	Hardware-isolated Real-Time Clock (RTC) plus tamper-proof, cryptographically chained logs.
How the Control Works	The RTC lives inside a protected MCU domain inaccessible to application software; each log entry is hashed and chained, so a retroactive edit breaks the chain.

BMS-T21 Ransomware [Software / Firmware]

What is it?	Malware that locks BMS functionality and demands payment to restore it.
Attack Mechanism	Delivered via a malicious update or compromised gateway, the malware encrypts critical configuration or control data and displays a ransom demand.
BMS Impact	System lockout, disrupted battery management, and potential vehicle immobilization.

Security Control	Secure boot combined with immutable, read-only partitions for critical firmware and configuration.
How the Control Works	Critical control code and configuration reside in a write-protected partition that ransomware cannot modify, leaving nothing for it to encrypt.

D. External & Ecosystem Attacks

Target the peripheral boundaries where the vehicle meets chargers, the cloud, the supply chain, and the grid.

Attack surface:

Charging interfaces/EVSE, V2G communication, cloud platforms and APIs, telematics systems, remote services, diagnostic interfaces, external vehicle networks, supply-chain software/hardware, and grid-connected interfaces.

Weakness:

These interfaces increase the number of systems that can interact with the BMS. Weak authentication, insecure APIs, insufficient access control, exposed diagnostic interfaces, insecure external communication, or compromised third-party components can provide an attacker with a path toward BMS-related systems.

BMS-T22 Charging Infrastructure / EVSE Attacks [External / Ecosystem]

What is it?	Attacks delivered through the physical charging connection or the ISO 15118 communication protocol.
Attack Mechanism	A compromised public fast charger injects malicious commands or an overcurrent request directly through the CCS/NACS plug, potentially bypassing vehicle-side firewalls.
BMS Impact	Battery pack bricking or induced thermal runaway.
Security Control	Mutual TLS-based Plug & Charge authentication (ISO 15118), with charge-parameter limits enforced independently inside the BMS.
How the Control Works	The vehicle and charger authenticate with certificates before power transfer, and the BMS enforces its own hard safety limits regardless of what the charger commands.

BMS-T23 Cloud / API Attacks [External / Ecosystem]

What is it?	Exploitation of weak cloud APIs or mobile-app backend infrastructure servicing the BMS fleet.
Attack Mechanism	Attacker locates an unauthenticated or weakly-authenticated API endpoint and sends spoofed firmware commands or state changes down to fleet BMS units.
BMS Impact	Wide-scale remote manipulation or immobilization across many vehicles simultaneously.
Security Control	Secure API gateway with strong authentication (OAuth/mTLS), RBAC, and rate limiting.
How the Control Works	Every API call must present a valid, scoped credential the gateway validates; RBAC restricts which commands a credential can issue.

BMS-T24 Telematics-to-BMS Attacks [External / Ecosystem]

What is it?	Lateral pivoting from the infotainment system or cellular modem into the high-voltage powertrain network.
Attack Mechanism	Attacker compromises the Telematics Control Unit (TCU) through a cellular or app-layer vulnerability, then attempts to reach the BMS via the internal gateway.
BMS Impact	Unauthorized access to high-voltage powertrain functions originating from a low-trust infotainment domain.
Security Control	Hardware-enforced network segmentation through a central gateway ECU equipped with an HSM.
How the Control Works	The gateway physically/logically separates the telematics domain from the HV domain and forwards only a small, pre-approved command whitelist.

BMS-T25 OBD-II / Diagnostic Attacks [External / Ecosystem]

What is it?	Unauthorized use of the physical diagnostic port to issue service-mode commands.
Attack Mechanism	A rogue device plugged into the OBD-II port under the dash sends unverified diagnostic or configuration-write commands.
BMS Impact	Unauthorized configuration changes and potential overriding of safety limits.
Security Control	UDS Security Access authentication (ISO 14229-1, Security Access Level 3+).
How the Control Works	Any write-level diagnostic command requires the tool to correctly answer a cryptographic challenge derived from an OEM-held key; rogue tools are limited to read-only.

BMS-T26 Supply-Chain Attacks [External / Ecosystem]

What is it?	Compromise of an upstream supplier to insert backdoors before the vehicle is even assembled.
Attack Mechanism	Attacker breaches a Tier-2 supplier's build/compilation server and inserts malicious code or components before delivery to the OEM.
BMS Impact	Backdoors present from the moment of manufacture, extremely difficult to detect through later testing.
Security Control	Code signing at every build stage, reproducible builds, and hardware attestation.
How the Control Works	Each build artifact is signed and verified at every handoff; a build tampered with at any stage produces a signature mismatch or fails reproducibility.

BMS-T27 V2G (Vehicle-to-Grid) Attacks [External / Ecosystem]

What is it?	Attacks on the interactive software layer used when the vehicle exports high-voltage power back to the home or grid.
Attack Mechanism	Attacker exploits the V2G communication/control software to send malicious export commands, potentially destabilizing the battery or connected circuit.
BMS Impact	Uncontrolled power export/import, breaker overload, and potential pack damage.
Security Control	The same ISO 15118 mutual authentication used for charging, plus BMS-side independent enforcement of export current/voltage limits.
How the Control Works	The BMS never blindly trusts external export commands — it clamps any requested power flow to pre-configured safe limits.

BMS-T28 Wireless BMS Attacks [External / Ecosystem]

What is it?	Exploitation of Bluetooth, Zigbee, or proprietary RF protocols used in wireless (wBMS) internal battery layouts.
Attack Mechanism	Attacker sniffs or replays wireless cell-monitor traffic to read individual cell voltage states or disrupt the wireless link.
BMS Impact	Data leakage of cell-level state, and potential forced safety cut-off if the link is disrupted at speed.
Security Control	AES-encrypted, mutually authenticated wireless links combined with FHSS.
How the Control Works	Rotating session keys and encrypted payloads prevent passive sniffing from yielding usable data, while frequency hopping prevents injection or jamming.

E. Emerging Threats from Grid, Cloud & Supply-Chain Integration

Vectors emerging as EVs deepen integration with grid infrastructure, cloud ecosystems, and automated assembly lines.

Attack surface:

Cloud-connected BMS services, remote/OTA update infrastructure, fleet-management platforms, grid/V2G interfaces, charging infrastructure, third-party software and components, manufacturing/assembly systems, automated production systems, and software/firmware supply chains.

Weakness:

The increasing connectivity between the vehicle, cloud, charging infrastructure, grid and supply chain creates additional trust relationships and external dependencies. A compromise of a connected service, third-party component, update infrastructure or manufacturing system could potentially be used to affect vehicles or BMS-related systems.

BMS-T29 Battery Recycling & 'Second-Life' Data Theft [Emerging / Ecosystem]

What is it?	Extraction of sensitive historical data from decommissioned BMS boards repurposed for stationary grid storage.
Attack Mechanism	Attackers physically access EEPROM memory chips on old BMS boards during second-life repurposing.
BMS Impact	Exposure of proprietary operational algorithms, user driving history, and cryptographic keys tied to the original manufacturer.
Security Control	Cryptographic key revocation and secure data wiping before decommissioning; encrypted-at-rest EEPROM storage.
How the Control Works	If keys are revoked and memory is encrypted with a key destroyed at decommissioning, extracted EEPROM contents are unreadable even with full physical access.

BMS-T30 Machine Learning Poisoning *[Emerging / Ecosystem]*

What is it?	Corruption of the cloud-trained machine learning models used to calculate fleet-wide battery degradation.
Attack Mechanism	Attackers feed bad charging logs or faulty edge-case data into the shared fleet training pool.
BMS Impact	Gradual degradation of estimation accuracy across thousands of vehicles, causing premature warranty claims or unexpected roadside breakdowns.
Security Control	Data provenance validation and robust/adversarial training with outlier rejection before data enters the training pool.
How the Control Works	Each training sample is checked against source authentication and statistical plausibility; poisoned samples are excluded before retraining.

3. Security Control Architecture

3.1 Controls by System Layer

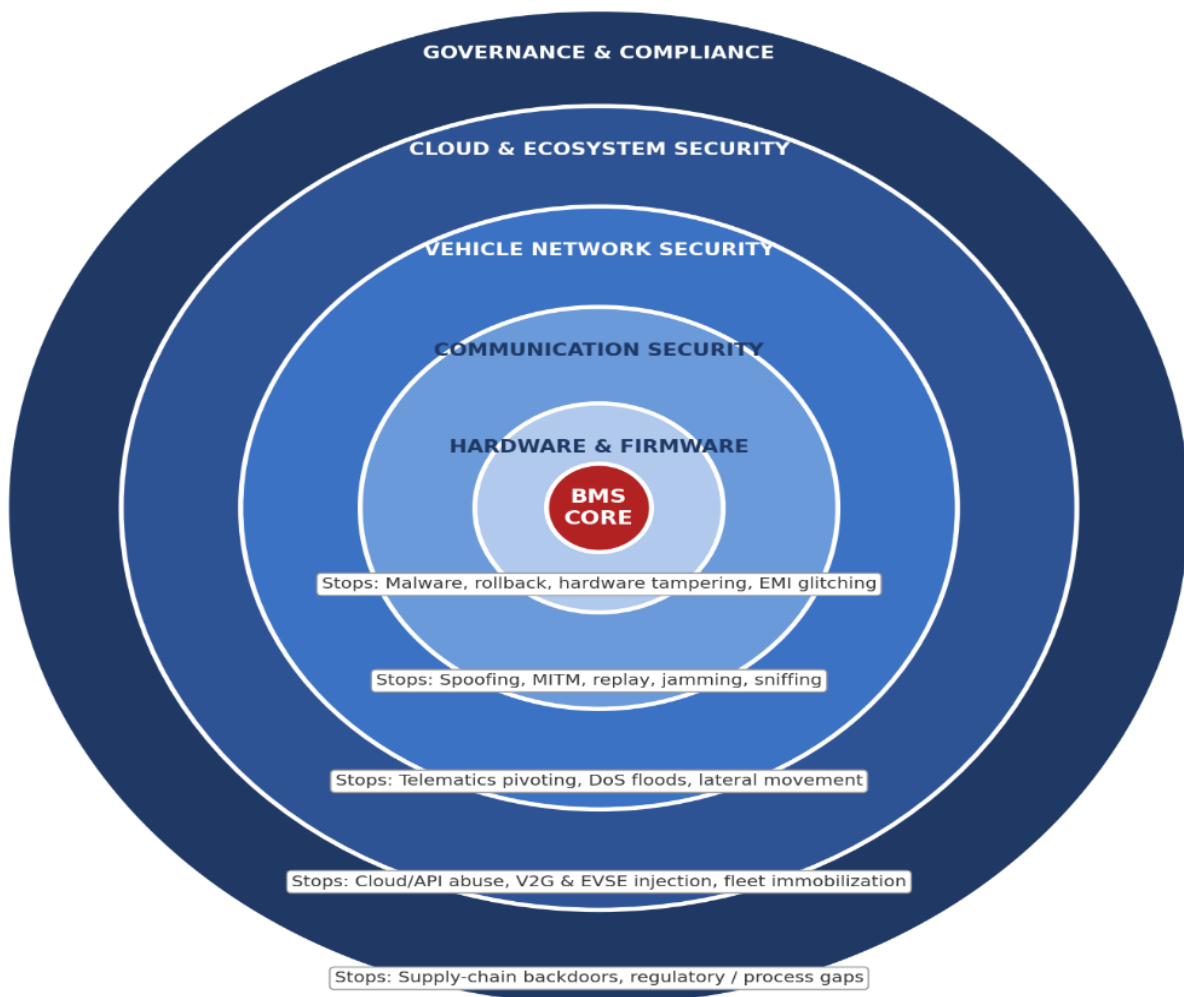
Beyond individual attack-control pairings, BMS security is engineered as a layered architecture — each layer closes off a different class of attack surface.

Layer	Control Measure	Functional Purpose
Hardware	Hardware Security Module (HSM)	Dedicated crypto-processor that isolates keys and accelerates real-time encryption.
Boot-up	Secure Boot & Root of Trust	Verifies the cryptographic signature of BMS firmware before execution, blocking malicious code.
Network	Secure CAN / SecOC	Appends a Message Authentication Code (MAC) to data packets to prove origin and neutralize bus injection.
Wireless	Mutual Authentication & AES	Cells register with the master module using short-lived rotating session tokens to defeat MITM.
Software	Anti-Rollback Protection	Hard-coded mechanism blocking forced downgrade to older, exploitable firmware.
Diagnostics	Secured Debug Interfaces	Automatically locks physical JTAG/SWD programming ports on the assembly line.

3.2 Defense-in-Depth Visualization

1. **The Starting Point (Governance/Process):** The attacker first looks for flaws in the supply chain, unpatched development environments, or human procedural errors.
2. **The Digital Entry (Cloud/Ecosystem):** They then exploit external connections, such as hacking a cloud API or sending a malicious signal through an EV charging station (EVSE).
3. **The Internal Network (Vehicle Network):** Once inside the vehicle's digital perimeter, they try to pivot laterally across the internal wiring (like the CAN bus) from the infotainment system toward the powertrain.
4. **The Command Line (Communication):** They attempt to spoof or replay valid commands to talk directly to the battery components.
5. **The Final Barrier (Hardware/Firmware):** Only after bypassing all network and communication protections does the attacker confront the physical chip protections, secure boot mechanisms, and firmware locks defending the BMS Core.

BMS Defense-in-Depth: Layered Security Architecture



4. Security Control-to-Cyber Threat Reference Matrix

A direct cross-reference from each control to the specific threat IDs it mitigates.

Security Control	Threats It helps mitigate
Message Authentication / SecOC	Spoofing, message injection, MITM (T02, T03)
Encryption (AES-256 / TLS 1.3)	Sniffing / confidentiality attacks (T01, T28)
Secure Boot	Malicious or unsigned firmware (T14, T16)
Digital Signatures	Unauthorized firmware / update packages (T15, T16)
Anti-Rollback Protection	Downgrade / rollback attacks (T17)
HSM / Secure Element	Key theft, hardware tampering (T10, T12)
Network Segmentation	Lateral movement / telematics-to-BMS pivoting (T24)
IDS / Anomaly Detection	DoS, injection, abnormal behaviour (T05, T07)
Sensor Redundancy / Plausibility Checks	Sensor manipulation and spoofing (T08, T09, T13)
Secure Diagnostics (UDS Security Access)	OBD-II / JTAG / diagnostic-port attacks (T25)
Freshness / Anti-Replay	T04 – Replay Attacks
Secure OTA	T16 – Malicious Firmware / OTA Attack; T17 – Rollback Attack
Authentication & Access Control	T22 – EVSE / Charging Interface Attacks; T23 – Cloud/API Attacks; T24 – Telematics-to-BMS Attacks; T25 – OBD-II / Diagnostic Attacks; T27 – V2G Exploitation
Secure Logging	T02 – Spoofing / Message Injection; T03 – Man-in-the-Middle; T04 – Replay Attacks; T14 – Malware Injection; T15 – Trojan Horse; T16 – Malicious Firmware / OTA Attack; T23 – Cloud/API Attacks; T25 – OBD-II / Diagnostic Attacks; T26 – Supply-Chain Attacks; T27 – V2G Exploitation

5. Security Controls

5.1 Message Authentication and Integrity

Message authentication ensures that a received message originated from an authorized source, while integrity protection ensures that the message has not been modified during transmission.

This is important in a BMS because attackers may attempt to inject or modify messages exchanged between battery-related ECUs.

How does it work?

A message can be accompanied by a Message Authentication Code (MAC) or another authentication mechanism. The receiving ECU verifies the authentication information before accepting the message.

In automotive systems, mechanisms such as Secure Onboard Communication (SecOC) can provide message authentication and integrity protection.

Sender → Message + Authentication Information → Receiver → Verification → Accept/Reject

If an attacker modifies the message or creates a message without valid authentication information, the receiving system can reject it.

BMS example

Suppose a legitimate ECU sends a message containing information used by the BMS to control battery operation. An attacker attempts to inject a message that tells the system:

"Battery operating condition is normal."

If the injected message does not contain valid authentication information, the receiving ECU can reject it.

Protects against

T2 Spoofing / Message Injection

T3 MITM modification

Unauthorized commands

Important limitation

Message authentication does not necessarily provide confidentiality. An attacker may still observe a message unless encryption is also used.

It should also be combined with a freshness mechanism to address replay attacks.

5.2 Encryption

Encryption converts readable information (plaintext) into an unreadable form (ciphertext) so that an unauthorized party cannot understand the information even if they intercept it.

How does it work?

The sender encrypts information using a cryptographic key, and an authorized receiver uses the appropriate key to decrypt it.

Plaintext → Encryption → Ciphertext → Decryption → Plaintext

Encryption can be particularly relevant to:

Wireless BMS communication

Vehicle-to-cloud communication

External APIs

Remote services

BMS example

Imagine a wireless BMS transmitting sensitive battery information between battery-monitoring components.

An attacker within radio range intercepts the communication.

Without encryption, the attacker may be able to read the transmitted information.

With encryption, the intercepted data appears as ciphertext and cannot be directly understood without the required cryptographic key.

Protects against

T1 Sniffing

Eavesdropping

Unauthorized disclosure of sensitive information

Important limitation

Encryption primarily provides confidentiality.

It does not by itself prove that the sender is legitimate.

Therefore:

Encryption ≠ authentication

5.3 Freshness Mechanisms / Anti-Replay Protection

A freshness mechanism ensures that a valid message cannot simply be captured and successfully reused later.

How does it work?

Common approaches include:

Sequence counters

Freshness counters

Timestamps

Nonces

BMS example

Suppose a legitimate message associated with a battery-management operation is transmitted at one point in time.

An attacker records that legitimate message and later retransmits it when the vehicle is in a different operating condition.

Although the original message was authentic, its old freshness value allows the receiving system to identify that it is not a current message.

Protects against

T4 Replay attacks

Reuse of previously valid commands/messages

Important limitation

Freshness mechanisms do not replace authentication.

The system generally needs to establish both:

"Is this message authentic?"

and

"Is this message current?"

5.4 Secure Boot

Secure Boot ensures that only authorized and trusted software/firmware is executed by the BMS controller.

It establishes a chain of trust beginning from a trusted component such as immutable boot code or a hardware root of trust.

How does it work?

A simplified process is:

Power on

↓

Trusted boot code executes

↓

Firmware authenticity/integrity verified

↓

Valid → Execute

Invalid → Reject / Recovery

BMS example

An attacker somehow modifies BMS firmware so that it changes how charging limits or thermal-management decisions are handled.

When the BMS controller starts, Secure Boot verifies the firmware.

If the modified firmware does not pass verification, the controller refuses to execute it.

Protects against

T14/15 Malware / Trojan

T16 Malicious Firmware / OTA

Unauthorized firmware

Firmware tampering

Important limitation

Secure Boot does not prevent someone from attempting to modify firmware.

It prevents unauthorized or invalid firmware from being trusted and executed, assuming the underlying trust chain remains secure.

5.5 Digital Signatures

Digital signatures allow a system to verify the authenticity and integrity of software or firmware before accepting it.

How does it work?

The legitimate software publisher signs the firmware using a private cryptographic key.

The BMS verifies the signature using the corresponding public key.

OEM firmware

↓

Private key → Digital signature

↓

Firmware delivered to vehicle

↓

BMS verifies signature

↓

Valid → Accept

Invalid → Reject

BMS example

Suppose an attacker modifies an OTA firmware package to change battery-management behaviour.

The modified firmware no longer corresponds to the original digital signature.

When the BMS verifies the package, the signature check fails and the update can be rejected.

Protects against

T14/15 Malware / Trojan

T16 Malicious Firmware / OTA
T26 Supply-chain attacks involving modified software
Tampered firmware

Relationship with Secure Boot

Digital signatures help establish that firmware is authentic and has not been modified.
Secure Boot helps ensure that only trusted/verified software is executed.

5.6 Anti-Rollback / Downgrade Protection

Anti-rollback protection prevents an attacker from installing an older firmware version that contains known vulnerabilities.
Why is it necessary?

Suppose:

Firmware v5 fixes a security vulnerability.

Firmware v2 contains that vulnerability.

v2 is still correctly signed by the manufacturer.

A signature check could establish:

"This firmware genuinely came from the manufacturer."

But the system must also determine:

"Is this version still permitted to run?"

How does it work?

The BMS maintains version information or another mechanism that prevents installation of firmware below an approved security level.

BMS example

A vehicle currently runs secure BMS firmware v5.

An attacker obtains the older but legitimately signed v2 firmware and attempts to install it because it contains a vulnerability that can be exploited.

The anti-rollback mechanism detects that v2 is older than the permitted security version and rejects the installation.

Protects against

T17 Rollback attacks

Downgrade attacks

Reintroduction of known vulnerabilities

Important relationship

Anti-rollback works together with:

Digital signatures

Secure Boot

Secure OTA

5.7 Hardware Security Module (HSM) / Secure Element

An HSM or secure element provides a protected hardware environment for security-sensitive operations, particularly cryptographic key storage and cryptographic operations.

Why is it important?

Cryptographic keys are extremely important to BMS security.

If an attacker compromises normal software and obtains a cryptographic key, they may be able to impersonate a legitimate system.

An HSM is designed to make direct extraction and unauthorized use of sensitive keys more difficult.

Functions can include

Secure key storage

Cryptographic operations

Authentication

Secure Boot support

Secure communication support

BMS example

A BMS controller uses cryptographic keys to authenticate messages.

Instead of storing those keys in ordinary application memory where they may be more exposed, sensitive keys can be protected using an HSM.

Even if an attacker compromises some of the controller's software, directly extracting the protected key can be made significantly more difficult.

Protects against

Cryptographic key theft

Unauthorized use of keys

Some hardware/software compromise

T10 Hardware Tampering

T11 Fault Injection

T14-16 Firmware attacks

Important limitation

An HSM is not a complete cybersecurity solution. It protects keys and security-sensitive operations, but the surrounding software and communication protocols must also be secure.

5.8 Network Segmentation and Secure Gateways

Network segmentation separates vehicle systems into different security domains so that compromising one system does not automatically provide unrestricted access to other systems.

A secure gateway can control and filter communication between these domains.

Why is it important for BMS?

A BMS should not necessarily be directly accessible from every vehicle interface.

A simplified architecture could be:

External system

↓

Telematics / Infotainment

↓

Security Gateway

↓

Protected vehicle network

↓

BMS

BMS example

An attacker compromises a vehicle's telematics system through an external interface.

Without appropriate segmentation, the attacker might attempt to move from the compromised system toward more critical vehicle networks.

A secure gateway can restrict which communications are allowed to reach the network containing the BMS.

Protects against

T23/24 Cloud / Telematics attacks

Lateral movement

Unauthorized network access

Some external-to-BMS attack paths

Important limitation

Segmentation does not necessarily prevent the initial compromise. Its purpose is to limit what the attacker can access afterward.

5.9 Intrusion Detection and Anomaly Detection

An Intrusion Detection System (IDS) monitors communication or system behaviour and identifies activity that appears malicious or abnormal.

How does it work?

The system can establish a baseline of normal behaviour, including:

Message frequency
Communication patterns
Expected commands
Sensor values
ECU interactions
It then looks for significant deviations.

BMS example

Suppose a particular CAN message normally appears approximately every 100 ms.
An attacker starts flooding the network with the same message thousands of times per second.
The abnormal message frequency can be detected by an IDS and an alert can be generated.

Protects against / detects

T2 Spoofing / Injection
T3 MITM
T5 DoS
T7 Fuzzing
T8 Sensor Manipulation
T19 False Data Injection
Other abnormal behaviour

Important limitation

IDS is primarily a detection mechanism, not necessarily a prevention mechanism.
It should therefore be combined with controls such as authentication, access control and segmentation.

5.10 Sensor Redundancy and Plausibility Checking

This is one of the most important controls specifically for BMS cybersecurity because the BMS depends heavily on sensor measurements.

Sensor redundancy uses multiple measurements or independent sources of information to increase confidence in the reported battery condition.

Plausibility checking determines whether a measurement makes sense when compared with other available information.

How does it work?

Instead of blindly trusting one measurement, the BMS can compare it against:

Other temperature sensors
Cell voltage
Current
Previous measurements
Expected rate of change
Battery operating conditions
Battery models

BMS example

Suppose one temperature sensor suddenly reports:
30°C → 90°C
while:
neighbouring cells remain around 30°C
current remains normal
there is no corresponding indication of heating
The BMS can identify the reading as suspicious rather than immediately trusting it.

Protects against

T8 Sensor Manipulation
Temperature spoofing
Voltage/current manipulation
T19 False Data Injection
Some T18 Modeling/Algorithm attacks

Important limitation

Sophisticated attackers may generate realistic-looking false data that passes simple plausibility checks.

Therefore, multiple independent measurements, sensor fusion and anomaly detection may be required for stronger protection.

5.11 Secure Diagnostics and Debug Protection

Diagnostic interfaces are required for vehicle servicing, testing and maintenance, but they can become an attack path if unauthorized users can access privileged functions.

Controls can include

Diagnostic authentication

Authorization

Secure diagnostic sessions

Debug-interface protection

Privilege separation

Access logging

BMS example

A service technician may need permission to:

Read battery diagnostic information.

However, that same diagnostic connection should not automatically give the technician or an attacker permission to:

Modify critical battery-management parameters.

Access should therefore depend on authentication and authorization.

Protects against

T25 OBD-II / Diagnostic attacks

Unauthorized configuration changes

Debug-interface abuse

Unauthorized service operations

5.12 Secure Over-the-Air (OTA) Updates

Secure OTA mechanisms ensure that software or firmware delivered remotely is authentic, has not been modified, and can be installed safely.

How does it work?

A secure OTA process can involve:

Authenticated update source

↓

Firmware integrity/authenticity verification

↓

Digital signature verification

↓

Version / anti-rollback check

↓

Secure installation

↓

Recovery if installation fails

BMS example

An OEM releases a new BMS firmware version to fix a vulnerability.

Before installation, the vehicle verifies:

The update came from an authorized source.

The firmware has not been modified.

The firmware has a valid digital signature.

The version is permitted and is not an unauthorized downgrade.

Only then is the update installed.

Protects against

T16 Malicious Firmware / OTA
T17 Rollback
Firmware tampering
Unauthorized updates

Important point

Secure OTA is not one individual security mechanism.
It combines several controls, including:
Authentication
Digital signatures
Integrity verification
Secure Boot
Anti-rollback
Secure recovery

5.13 Authentication and Access Control

Authentication determines who or what is requesting access.
Authorization/access control determines what that authenticated entity is allowed to do.

Examples

For cloud/fleet systems:
User authentication
Multi-factor authentication
Role-based access control (RBAC)
Privilege management
For vehicle/BMS communication:
ECU/device authentication
Diagnostic authentication
Authorized service access

BMS example

A technician may be authenticated and allowed to:
Read battery diagnostic information
but may not be authorized to:
Change critical charging or protection parameters.
This limits the damage that can be caused even if an account or credential is compromised.

Protects against

Unauthorized access
Privilege abuse
T22/27 EVSE/V2G access attacks
T23 Cloud/API attacks
T25 Diagnostic attacks

Important limitation

Authentication alone does not determine what a user is permitted to do.
Therefore:
Authentication + Authorization
are both required.

5.14 Secure Logging and Tamper Protection

Security logging records important events so that suspicious activity can be detected and investigated.
For cybersecurity purposes, logs should also be protected against unauthorized modification.
Information that can be logged includes:
Authentication attempts
Diagnostic access
Firmware updates

Security alerts
Configuration changes
Detected anomalies
Relevant system events

BMS example

Suppose an unauthorized diagnostic session attempts to change a battery-management parameter.

A secure logging mechanism can record:

The diagnostic access attempt → time → relevant system/event information → result.

If an attacker later tries to delete or modify the record, integrity protection can help identify unauthorized modification.

Protects against / supports

T20 Timestamp / Log Manipulation
Attack investigation
Incident detection
Forensic analysis
Accountability

Important limitation

Logging generally does not prevent an attack. It supports detection, investigation and response.

6. Key Security Measures for BMS

6.1 Securing Communication & Data Integrity

- End-to-end encryption (AES-256, TLS 1.3) for data transfer between the BMS and cloud systems.
- Cryptographic authentication on all firmware updates to prevent malicious modification.
- Secure communication protocols such as MQTT-over-TLS and HTTPS for remote monitoring and control.

6.2 Strengthening Access Control & Authentication

- Multi-Factor Authentication (MFA) for all remote BMS access points.
- Role-Based Access Control (RBAC) to restrict data access according to defined user roles.
- Digital signatures to verify the authenticity of every firmware update.

6.3 Intrusion Detection & Anomaly Monitoring

- AI-based anomaly detection to identify deviations in battery behaviour indicating a cyberattack.
- Real-time Intrusion Detection System (IDS) for continuous network traffic analysis.

6.4 Securing Network Interfaces & Connectivity

- Isolating BMS networks from public networks using firewalls and VPNs.
- A secure API gateway to monitor and validate third-party interactions.
- Regular penetration testing to identify and close vulnerabilities.

6.5 Firmware & Hardware Security Enhancements

- Secure boot mechanisms to ensure only authorized firmware runs on the BMS.
- A Hardware Security Module (HSM) integrated for secure cryptographic key storage.

7. Roadmap for a Cyber-Resilient BMS

Step 1 — BMS Security Assessment

- BMU & CMU Security: identify firmware vulnerabilities, secure real-time data, prevent false SoC/SoH reports.
- Gateway & Network Security: secure CAN, Modbus, MQTT, and OPC-UA interfaces.

Step 2 — Security by Design

- Hardware Security: secure bootloaders and encrypted firmware storage.
- Secure Communication: AES-256, TLS 1.3, and certificate-based authentication for BMS-to-cloud/vehicle connectivity.
- Data Integrity: tamper-proof logs and cryptographic SoC/SoH validation.

Step 3 — Secure Firmware & OTA Updates

- Encrypted OTA updates secured with digital signatures and rollback protection.
- AI-powered threat detection to identify abnormal firmware behaviour and isolate threats.

Step 4 — Managed Cybersecurity Services

- 24/7 threat monitoring, anomaly detection, and automated alerting.
- Regulatory compliance with ISO 21434, UNECE WP.29 R155/R156, and IEC 62443.
- Ongoing BMS penetration testing across firmware, hardware, and network layers.

8. Regulatory Alignment

Mitigation is framed within recognized automotive cybersecurity standards rather than controls in isolation:

- **ISO/SAE 21434 — Road Vehicles Cybersecurity Engineering: risk assessment and security-by-design lifecycle.**

Core Focus: Establishes the organizational and engineering framework for cybersecurity.

Key Mechanism: Defines TARA (Threat Analysis and Risk Assessment) to identify assets, vulnerabilities, and threats.

Application: defines a "Security-by-Design" lifecycle from initial concept, through development, production, operation, and eventual decommissioning.

- **UNECE WP.29 R155 — Cybersecurity Management System (CSMS), mandatory for type approval in UNECE markets.**

Core Focus: Legally mandates risk management for vehicle type approval in participating global markets.

Key Mechanism: R155 requirements are supported by the cybersecurity engineering processes defined in ISO/SAE 21434.

Application: OEMs must prove they can detect, defend against, and respond to cyber threats across the entire vehicle fleet.

- **UNECE WP.29 R156 — Software Update Management System (SUMS), governing OTA update security.**

Core Focus: Governs the secure delivery of software updates, specifically Over-the-Air (OTA).

Key Mechanism: Ensures update authenticity, prevents malware injection, and guarantees vehicle safety during the update process.

Application: Requires strict tracking of software versions and dependencies across all vehicle configurations.

- **IEC 62443 — Industrial/embedded control-system security, Industrial automation and control-system cybersecurity; relevant where BMS manufacturing and automated production environments are considered**

Core Focus: Secures the industrial supply chain and embedded components.

Key Mechanism: Applies defense-in-depth strategies to operational technology (OT).

Application: Hardens Battery Management Systems (BMS) firmware, electronic control units (ECUs), and the automated factory environments where they are flashed.